Hack The Box: Brutus

Penulis: Firman Maulana

Pada lab kali ini kita akan belajar menganalisa sebuah log, dimana di lab ini disediakan auth.log dan wtmp, skenario dalam lab tersebut yaitu terdapat anomali yang melakukan brute force melalui SSH, untuk mengenali pola brute force ini yang terpenting yaitu analisa pada auth.log, untuk mengakses labnya klik *disini* yaa!

Langsung saja mari kita mulai petualangan ini!!

Proses Analisa

Langsung saya kita buka file yang disediakan di lab tersebut dengan sandi yang di sediakan, langkah pertama kita membuka file auth.log, saya membuka melalui menu direktori pada kali linux.

- **Analisis auth.log. Apa alamat IP yang digunakan oleh penyerang untuk melakukan serangan brute force?**

```
 95 Mar  6 06:31:31 ip-172-31-35-28 sshd[2334]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
 96 Mar  6 06:31:31 ip-172-31-35-28 sshd[2336]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
    user=backup
 97 Mar  6 06:31:31 ip-172-31-35-28 sshd[2330]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
 98 Mar  6 06:31:31 ip-172-31-35-28 sshd[2328]: pam_unix(sshd:auth): check pass; user unknown
 99 Mar  6 06:31:31 ip-172-31-35-28 sshd[2328]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
100 Mar  6 06:31:31 ip-172-31-35-28 sshd[2333]: Invalid user admin from 65.2.161.68 port 46452
101 Mar  6 06:31:31 ip-172-31-35-28 sshd[2329]: pam_unix(sshd:auth): check pass; user unknown
102 Mar  6 06:31:31 ip-172-31-35-28 sshd[2329]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
103 Mar  6 06:31:31 ip-172-31-35-28 sshd[2333]: pam_unix(sshd:auth): check pass; user unknown
104 Mar  6 06:31:31 ip-172-31-35-28 sshd[2333]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
105 Mar  6 06:31:31 ip-172-31-35-28 sshd[2352]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
    user=backup
106 Mar  6 06:31:31 ip-172-31-35-28 sshd[2351]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
    user=backup
107 Mar  6 06:31:31 ip-172-31-35-28 sshd[2355]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
    user=backup
108 Mar  6 06:31:32 ip-172-31-35-28 sshd[2357]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
    user=backup
109 Mar  6 06:31:33 ip-172-31-35-28 sshd[2327]: Failed password for invalid user admin from 65.2.161.68 port 46392 ssh2
110 Mar  6 06:31:33 ip-172-31-35-28 sshd[2331]: Failed password for invalid user admin from 65.2.161.68 port 46436 ssh2
111 Mar  6 06:31:33 ip-172-31-35-28 sshd[2332]: Failed password for invalid user admin from 65.2.161.68 port 46444 ssh2
112 Mar  6 06:31:33 ip-172-31-35-28 sshd[2335]: Failed password for invalid user admin from 65.2.161.68 port 46460 ssh2
113 Mar  6 06:31:33 ip-172-31-35-28 sshd[2337]: Failed password for invalid user admin from 65.2.161.68 port 46498 ssh2
114 Mar  6 06:31:33 ip-172-31-35-28 sshd[2334]: Failed password for invalid user admin from 65.2.161.68 port 46454 ssh2
115 Mar  6 06:31:33 ip-172-31-35-28 sshd[2338]: Failed password for backup from 65.2.161.68 port 46512 ssh2
```

```
309 Mar  6 06:31:41 ip-172-31-35-28 sshd[2407]: Connection closed by authenticating user root 65.2.161.68 port 46876 [preauth]
310 Mar  6 06:31:41 ip-172-31-35-28 sshd[2407]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68  user=root
311 Mar  6 06:31:42 ip-172-31-35-28 sshd[2409]: Connection closed by authenticating user root 65.2.161.68 port 46890 [preauth]
312 Mar  6 06:31:42 ip-172-31-35-28 sshd[2409]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68  user=root
313 Mar  6 06:31:42 ip-172-31-35-28 sshd[2423]: Failed password for backup from 65.2.161.68 port 34834 ssh2
314 Mar  6 06:31:42 ip-172-31-35-28 sshd[2424]: Failed password for backup from 65.2.161.68 port 34856 ssh2
315 Mar  6 06:31:44 ip-172-31-35-28 sshd[2423]: Connection closed by authenticating user backup 65.2.161.68 port 34834 [preauth]
316 Mar  6 06:31:44 ip-172-31-35-28 sshd[2424]: Connection closed by authenticating user backup 65.2.161.68 port 34856 [preauth]
317 Mar  6 06:32:01 ip-172-31-35-28 CRON[2477]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
318 Mar  6 06:32:01 ip-172-31-35-28 CRON[2476]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
319 Mar  6 06:32:01 ip-172-31-35-28 CRON[2476]: pam_unix(cron:session): session closed for user confluence
320 Mar  6 06:32:01 ip-172-31-35-28 CRON[2477]: pam_unix(cron:session): session closed for user confluence
321 Mar  6 06:32:39 ip-172-31-35-28 sshd[620]: exited MaxStartups throttling after 00:01:08, 21 connections dropped
322 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
323 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
324 Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
325 Mar  6 06:33:01 ip-172-31-35-28 CRON[2561]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
```

Setelah saya analisa terdapat IP mencurigakan karena melakukan login berulang dan gagal, hal ini menandakan IP tersebut sedang melakukan brute force sesui skenario pada lab ini, IP tersebut adalah **65.2.161.68**

Anomali tersebut berhasil login menggunakan brute force dengan port 53184 SSH2

- **Upaya bruteforce berhasil dan penyerang mendapatkan akses ke akun di server. Apa nama pengguna akun?**

```
321 Mar  6 06:32:39 ip-172-31-35-28 sshd[620]: exited MaxStartups throttling after 00:01:08, 21 connections dropped
322 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
323 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
324 Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
325 Mar  6 06:33:01 ip-172-31-35-28 CRON[2561]: pam_unix(cron:session): session opened for user confluence(uid=998) by (uid=0)
```

Nama user pada server tersebut adalah **root**, terlihat setelah anomali tersebut berhasil login setelah gagal berkali-kali login

- **Identifikasi stempel waktu UTC saat penyerang masuk secara manual ke server dan membuat sesi terminal untuk melaksanakan tujuan mereka. Waktu login akan berbeda dari waktu otentikasi, dan dapat ditemukan di artefak wtmp**

```
322 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
323 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
```

```
┌──(kali㉿kali)-[~/Downloads/_Brutus.zip.extracted]
└─$ python3  utmp.py wtmp | grep 65.2.161.68
"USER"  "2549"  "pts/1" "ts/1"  "root"  "65.2.161.68"   "0"     "0"     "0"     "2024/03/06 01:32:45"   "387923"        "65.2.161.68"
"USER"  "2667"  "pts/1" "ts/1"  "cyberjunkie"   "65.2.161.68"   "0"     "0"     "0"     "2024/03/06 01:37:35"   "475575"        "65.2.161.68"
```

pada waktu di log auth.log dengan wtmp memiliki perbedaan, seharusnya perbedaannya 1–2 detik saja, mungkin terdapat sedikit eror terhadap data maka jawawaban nya yaitu **2024–03–06 06:37:45**

Sesi login SSH dilacak dan diberi nomor sesi saat masuk. Berapa nomor sesi yang ditetapkan ke sesi penyerang untuk akun pengguna dari Pertanyaan 2?

```
322 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
323 Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
324 Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

session 37 disaat penyerang berhasil login di server tersebut dengan SSH

- **Penyerang menambahkan pengguna baru sebagai bagian dari strategi persistensi mereka di server dan memberikan hak istimewa yang lebih tinggi kepada akun pengguna baru ini. Apa nama akun ini?**

```
359 Mar  6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Removed session 37.
360 Mar  6 06:37:34 ip-172-31-35-28 sshd[2667]: Accepted password for cyberjunkie from 65.2.161.68 port 43260 ssh2
361 Mar  6 06:37:34 ip-172-31-35-28 sshd[2667]: pam_unix(sshd:session): session opened for user cyberjunkie(uid=1002) by (uid=0)
362 Mar  6 06:37:34 ip-172-31-35-28 systemd-logind[411]: New session 49 of user cyberjunkie.
```

Penyerang mengubah user pada server tersebut untuk mengambil alih server. User baru tersebut yaitu **cyberjunkie.**

- **Jam berapa sesi SSH pertama penyerang berakhir menurut auth.log?**

```
355 Mar  6 06:37:24 ip-172-31-35-28 sshd[2491]: Received disconnect from 65.2.161.68 port 53184:11: disconnected by user
356 Mar  6 06:37:24 ip-172-31-35-28 sshd[2491]: Disconnected from user root 65.2.161.68 port 53184
357 Mar  6 06:37:24 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session closed for user root
358 Mar  6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Session 37 logged out. Waiting for processes to exit.
```

Sesi pertama berakhir pada pukul **2024–03–06 06:37:24,** dimana terdapat status session closed pada log tersebut seperti pada gambar di atas.

- **Apa ID sub-teknik MITRE ATT&CK yang digunakan untuk persistensi dengan membuat akun baru?**

Teknik yang digunakan penyerang adalah dalam framework MITRE ATK&CK, yaitu dengan subteknik T1136.001. Pihak penyerang dapat membuat akun lokal untuk mempertahankan akses ke sistem korban. Akun lokal adalah akun yang dikonfigurasi oleh suatu organisasi untuk digunakan oleh pengguna, dukungan jarak jauh, layanan, atau untuk administrasi pada satu sistem atau layanan.

- **Penyerang masuk ke akun backdoor mereka dan menggunakan hak istimewa mereka yang lebih tinggi untuk mengunduh skrip. Apa perintah penuh yang dijalankan menggunakan sudo?**

```
333 Mar  6 06:34:18 ip-172-31-35-28 groupadd[2586]: group added to /etc/group: name=cyberjunkie, GID=1002
334 Mar  6 06:34:18 ip-172-31-35-28 groupadd[2586]: group added to /etc/gshadow: name=cyberjunkie
335 Mar  6 06:34:18 ip-172-31-35-28 groupadd[2586]: new group: name=cyberjunkie, GID=1002
336 Mar  6 06:34:18 ip-172-31-35-28 useradd[2592]: new user: name=cyberjunkie, UID=1002, GID=1002, home=/home/cyberjunkie, shell=/bin/bash, from=/dev/pts/1
337 Mar  6 06:34:26 ip-172-31-35-28 passwd[2603]: pam_unix(passwd:chauthtok): password changed for cyberjunkie
```

Terdapat perintah useradd yangdigunakan untuk membuat akun baru untuk mempertahankan akses penyerang di server target.

Seluruh pertanyaan pada lab ini akhirnya terjawab, seperti itulah cara bagaimana menganalisa log serangan dari brute force, dalam dunia forensik artefak adalah hal yang berharga untuk mencari tahu jika terjadi suatu kejadian seperti ini contohnya, dimana informasi penting terkadang terdapat didalamnya, dan nantinya digunakan untuk bukti di persidangan, sebuah ketelitian adalah kunci agar bisa menelusuri isi artefak tersebut.